

School of Computer Science and Engineering, UNSW



Never Stand Still

WK09-01: Characteristics & Limitations:
Security, Privacy, Data Quality and Interoperability

Software Architecture for Blockchain Applications,
COMP6452

Salil Kanhere, Nadeem Ahmed

Agenda

Security

Privacy

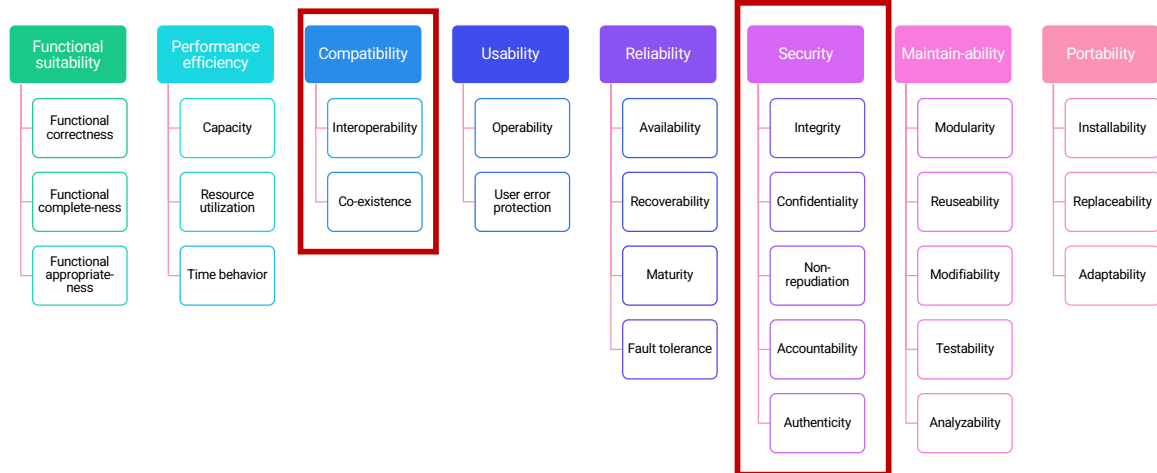
Data quality

Interoperability

- Layer 2 mechanisms

- We'll start with an introduction to security and discuss several aspects of security like integrity and confidentiality.
- Then, we'll cover data privacy.
- We'll conclude the topic with a discussion on data quality and interoperability on blockchain.
- ISO quality model has security & Interoperability but no privacy and data quality.

ISO/IEC 25010:2011 Quality Model



WK 09-01

3



- International standards for evaluation of software quality, ISO/IEC 25010:2011 Quality Model, define many software qualities.
- Other than functional suitability all other qualities are non-functional. Under each group, there are multiple quality metrics.
- In this topic, we'll focus on a subset of properties under the 2 highlighted ones.

Scope of Blockchain-based Applications Security

Smart contracts	Cryptography & Key management
Blockchain platform	Access control & KYC
• Consensus • Smart contract language & execution-environment	Privacy
DApp architecture	Infrastructure, especially for private blockchains
Integration with external systems	Business continuity & disaster recovery
Data management	Governance & compliance

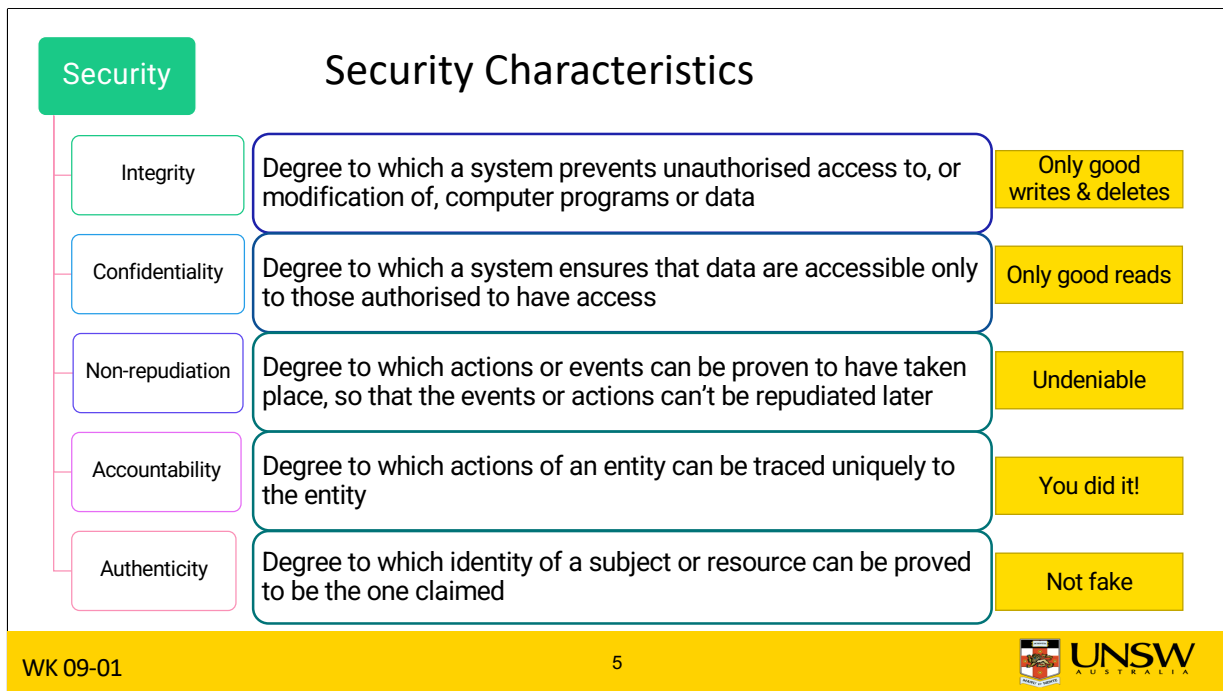
WK 09-01

4



- When we think about blockchain security, most people only consider smart contract security. Security testing of smart contracts includes both code-level testing and run-time testing.
- But as we saw from the previous graph, to make sure a blockchain-based application is secure, we need to make sure many aspects/components of the system are secure.
- This is ensured by secure design and extensive testing. What specific tests and depth of testing can depend on the importance of the application.
- The choice of the blockchain platform is the main consideration. The key focus should be the blockchain platform's consensus mechanism, its use of cryptography, and smart contract language and execution environment.
 - If the blockchain platform is well-established and time-tested you have some level of assurance and a good understanding of how it works.
 - If it's a new platform, then you need to review and test everything from its design, protocols, and smart contract execution environment.
- Software architecture should be designed to achieve security (i.e., secure by design). Architecture testing is a qualitative review of the design to determine its soundness in dealing with potential security issues.
- Integration with external systems, how we manage data, cryptography and key management, access control and KYC, and privacy are other design considerations. They can also be tested once developed.
- We should choose, configure, and test the infrastructure that was chosen to host the blockchain and other components of the application. This is particularly important for private blockchains.
- Business continuity and disaster recovery are also important. If you are hosting the blockchain platform you need to think about the number of nodes and where they are located to enhance availability.
- Blockchain governance is all about how you manage the platform from the addition of a new node and users, updating smart contracts to who pay for what and how issues are resolved.
- If your application needs to comply with certain regulations, then you may also have some reporting requirements to show compliance. While some authority may run a node, you may still have other obligations to ensure you design the system considering such compliance needs and continue to operate satisfying these compliance needs.
- So the following discussion applies to all aspects of smart contracts, blockchain, and components that integrate with it.

KYC – Know Your Customer



- ISO/IEC 25010:2011 standard includes several security characteristics.
 - While the CIA (confidentiality, integrity, and availability) triad in security includes availability, ISO/IEC 5010:2011 treats availability as a “reliability” characteristic.
- Integrity is the degree to which a system, product, or component prevents unauthorised access to, or modification of, computer programs or data. This essentially means we should only allow good writes and deletes, e.g., no one without authorisation should be able to update a smart contract’s state.
- Confidentiality is the degree to which a product or system ensures that data are accessible only to those authorised to have access. This means making sure only authorised users are allowed to read data, e.g., only the manager can add voters and restaurants.
- Non-repudiation is the degree to which actions or events can be proven to have taken place so that the events or actions can’t be repudiated later. Essentially it is the inability to deny an action, e.g., if a transaction is signed with your private key, it authenticates you as the sender.
- Accountability is the degree to which actions of an entity can be traced uniquely to the entity. This is about being able to pinpoint who did what, e.g., the ability to track voters and their votes.
- Authenticity is the degree to which the identity of a subject or resource can be proved to be the one claimed. It is the ability to prove it is the real thing, e.g., proving the validity of an NFT. This also applies to the real-world identity of users as well.

Integrity

Clark-Wilson policy model is a classic model of integrity

Clark-Wilson Policy Model	How Blockchains Stack Up
Start with a well-formed initial state	Initial state (i.e., genesis block) is well-formed & cross-checked by all miners
Transformation procedures preserve well-formedness & checked using integrity validation procedures	Mining & cross-checking other miners' blocks to ensure validity of TXs & blocks
Only authorised users make changes	Authorisation is checked using digital signatures
Separation of duty	No separation of duty enforced. "Admin changes" are by mining collective (i.e., governance body), e.g., hard forks
User actions are tracked	Ledger is system state & audit log

WK 09-01

6



- Integrity is the degree to which a system, product, or component prevents unauthorised access to, or modification of, computer programs or data.
- The Clark-Wilson policy model is a classic model of integrity.
 - Integrity is maintained by preventing the corruption of data items in a system due to either error or malicious intent. Based on double-entry bookkeeping.
 - Start with a well-formed initial state.
 - When changing the state, "transformation procedures" preserve state well-formedness.
 - "Integrity validation procedures" are used to check conditions for "constrained data items".
 - Only authenticated and authorised users can make changes.
 - Also, ensure appropriate "separation of duty", e.g., a party that initiates a transaction cannot approve the transaction.
 - Audit logs and controls on admin changes are tracked.
- Clark-Wilson perspective on blockchain integrity
 - The initial state (i.e., genesis block) is well-formed and cross-checked by all miners.
 - Mining and cross-checking other miners' blocks and transactions is a "Transformation Procedure". Miners' block validation checks are "Integrity Validation Procedure". With the building of a new block, the system moves from one consistent discrete state to another.
 - Blocks and their transactions are the "Constrained Data Items".
 - While the generation of a new block in public blockchains creates new cryptocurrency (or sometimes crypto is burnt to increase value), it is still within the rules of the system as the conversation of money is preserved as per the system rules.
 - An authorisation is checked using digital signatures. This applies to transactions and miners (in permissioned networks). No authentication on public blockchains! Often important on private blockchains.
 - No separation of duty is enforced. "Admin changes" are by the mining collective (i.e., governance body). When you don't agree it can lead to a hard fork, the ultimate way of solving conflicts.
 - The blockchain ledger is the system state and audit log that track everything.
- Example integrity conditions in blockchains:
 - Were transactions against an address signed by the corresponding private key?
 - Does the sending address have enough cryptocurrency?
 - Did a miner give themselves the right mining reward?
 - Did execution recorded for a smart contract give the same result I get?

Integrity for Components in DApps

On-chain data integrity is preserved

- Data may have been altered before recorded in blockchain (aka garbage in, garbage out problem)

Can enhance off-chain data integrity

- Record data hash on-chain as Proof of Existence (PoE)
- Record authorisations for off-chain data access on-chain
- Smart contract cross-checks off-chain computations

TX order on blockchain & DApp may not be same

- TXs from different addresses reorder
- TXs from same address may reorder on some blockchains

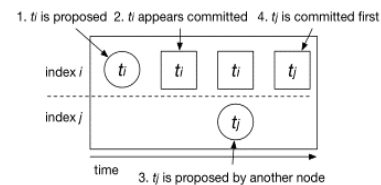


Figure 3: The Blockchain anomaly: a first client issues t_i that gets successfully mined and committed then a second client issues t_j , with t_j being conditional to the commit of t_i (note that $j \geq i + k$ for t_j to be committed before t_i gets issued), but the transaction t_j gets finally reorganised and successfully committed before t_i , hence violating the dependency between t_i and t_j

Source: "The Blockchain Anomaly"
<https://arxiv.org/pdf/1605.05438>

- Blockchains can enhance the integrity of components in blockchain-based applications.
- As discussed in the previous slide, by design, blockchain maintains the integrity of data on-chain.
 - However, before submitting data to a blockchain, data may have been altered off-chain. E.g., while issuing a token that records the ownership of an asset, we may rely on an off-chain database to identify ownership information. If that database was compromised, we might be issuing a token to the wrong owner.
 - This problem is known as the "garbage in garbage out problem" because the blockchain can't verify the integrity of data fed into the blockchain.
- Blockchain can enhance off-chain data integrity, e.g.,
 - We can record the hash of data on-chain as proof of its existence. This is called Proof of Existence (PoE). But we can't recover data in case of an integrity violation.
 - We can also record authorisations for off-chain data access on-chain. This could also be done dynamically based on a set of transactions, we can record the authorisation on-chain that off-chain application components can check before allowing access to data.

- A smart contract may cross-check off-chain computations to verify a certain computation was performed correctly.
- We consider blockchain transactions to be in a strict order and immutable or are they?
 - Nakamoto consensus can give us alternative/replacement histories.
 - E.g., as seen in the figure, we first issue a transaction. Then we wait till it gets included in a block. Soon after, we issue a 2nd transaction that depends on the 1st one. But due to the Nakamoto consensus, 1st transaction may go back to the transaction pool and later get included in a block (or may never be included).
 - This is a possible anomaly where integrity is not preserved on-chain and off-chain.
 - Both need to be independently “valid” from the perspective of a blockchain and application. But it is invalid to the application when reordered. This is not a new problem. But something we need to be aware of and take action on if that’s a problem in certain cases.
- TXs are known to record in blockchains.
 - Transactions from different addresses to the same receiver address could reorder.
 - Transactions from the same address may reorder on some blockchains.
 - There are some solutions to minimise the impact of these issues:
 - Wait for more confirmation blocks. But the question is how long?
 - Ethereum transaction nonce (this is different from block nonce) can order Transactions from the same sender address.
 - Smart contract to enforce/check order.

Confidentiality

Might Use ...	But ...
Pseudonymous addresses	If addresses are re-used, can recover identity information
Private blockchain	All nodes are authorised to see all data!
DLTs where ledgers & TXs are shared only with parties of interest, e.g., Hyperledger Fabric & R3 Corda	- Orderer in Hyperledger Fabric see all TXs - R3 Corda relies on notaries to prevent double-spending - Patterns from TX analytics, e.g., volume & frequency - Not straightforward to identify who can see what
Encryption for on-chain confidential data	- Complex key management - Limits what smart contracts can do with data - Key loss reveals all old data - Quantum computing or others may break crypto scheme
Keep data off-chain, use conventional technologies for access control	- Limits data integrity - Limits what smart contracts can do with data - More complex system design - Less value directly from blockchain for sharing data

WK 09-01

8



- Confidentiality is the degree to which a product or system ensures that data are accessible only to those authorised to have access.
- As we already discussed a couple of times, blockchain platforms aren't good for confidentiality because mining nodes cross-check the contents of all transactions and maintain a copy of the ledger.
- Even if a party doesn't see the transaction data, they can still see metadata about them to understand things like transaction volume and frequency of interactions.
- Here are a few examples of things one may try to enhance confidentiality and their limits
- Other than in enterprise blockchains, we use pseudonymous addresses for accounts.
 - However, if addresses are re-used, one may be able to recover identity information by looking at IP addresses or linking to off-chain discussions to reveal the party. One solution is to use a new pseudo address for each transaction. While this work, it could be a management nightmare.
- While confidentiality is better with private blockchains, as only the authorised parties are in the blockchain, all of them are authorised to see all transactions and ledger state.
- You may try to further improve by using a private-permissioned blockchain/DLT where ledgers and transactions are shared only with parties of interest, e.g., R3 Corda & Hyperledger Fabric. However, we have the following challenges:
 - The orderer in Hyperledger Fabric sees all transactions. You can try to partition orders for different channels or use Private Data Collections (PDCs) which can be complicated to implement.
 - R3 Corda relies on notaries to prevent double-spending. So notaries see all transactions they attest. There's some work to improve this; e.g., ING has proposed a technique to improve Corda privacy with zero-knowledge notaries.
 - Even though a 3rd party does not have access to transaction data or ledger, it can still analyse transaction patterns to identify which parties transact (remember that identities are typically known in private/enterprise blockchains), when, and how frequently.
 - Given many parties and complex policies, it's not straightforward to identify who can see what?
- Encryption for on-chain confidential data is another option. However, this comes with a few challenges:
 - This results in complex key management. E.g., you may need a different private/public key pair. Or if you use symmetric keys, they need to be shared with the party that is expected to decrypt the data.
 - Encrypted data substantially limits what smart contracts can do with them, e.g., while it's possible to use homomorphic encryption to perform some operations on data (e.g., add and multiply), it's quite limited and computationally expensive.
 - Also, a key loss reveals all old data too. This means we need to change the key, which further complicates key management frequently.
 - There is also the risk that quantum computing or other new techniques may break the crypto schemes in future.
- Given all these troubles, one may try to keep data off-chain and rely on conventional technology for access control.
 - When you do this we lose the strong integrity guarantees that blockchains provide to data and limit what smart contracts can do with the data.
 - This may result in a more complex system design.
 - It also limits the value that you can gain from directly sharing data via blockchain.

Non-Repudiation

Immutable ledger state & TXs

- Probabilistic immutability in Nakamoto consensus
- Wait for a suitable number of confirmation blocks based on DApp's risk profile

TX signature confirms integrity of TX data & sender's address, but

- Sender might have recorded false data in TX
- Someone might have stolen the private key
- Through a TX can record hash of off-chain data, nothing can be done if that data are modified or lost

Only have non-repudiation that TX happened

- Non-repudiation is the degree to which actions or events can be proven to have taken place so that the events or actions can't be repudiated later. This about transaction sender not being able to deny the transaction.
- Immutable ledger state and transactions prove what actions took place on the blockchain.
 - But be careful of probabilistic immutability in the Nakamoto consensus. An updated ledger state or transaction doesn't mean anything if it's not included in the heaviest chain.
 - Hence, we need to wait for a suitable number of confirmation blocks based on your application's risk profile. While there are well-accepted numbers for different platforms (e.g., 6 for Bitcoin), you may want to wait a bit more if you need extremely high probabilistic guarantees.
- A digital signature attached to a TX confirms the integrity of the data attached to the TX and the sender's address. However, just because a transaction is signed and data are recorded on-chain, doesn't mean it's true!
 - The sender might have fraudulently recorded false data in a transaction.
 - Someone might have stolen your private key.
 - If the transaction includes hashes of off-chain data, need to retain the original data. Otherwise, nobody knows whether the data you recorded really mean anything.
- Therefore, the only form of non-repudiation we have in blockchains is that TX happened, but not about its actual sender or the data it embeds.

Accountability

TX signature may be the only trace a party leaves

- Does a single party control the private key?
- Good key management is critical!

Most public blockchains try not to provide accountability

- Pseudonymous IDs are too weak to prevent re-identification
- Cryptocurrencies like Zcash, Dash, & Monero try to provide anonymity like cash

Private blockchains are normally permissioned; hence, know who users are

KYC/AML-CTF

- Know Your Customer / Anti-Money Laundering, Counter-Terrorism Financing
 - e.g., Australian AUSTRAC regulation requires KYC/AML by crypto-currency exchanges
- Authentication requires off-chain mechanisms to establish identity
- Blockchain can be used to communicate or protect integrity of KYC information

WK 09-01

10



- Accountability is the degree to which actions of an entity can be traced uniquely to the entity. This requires keeping track of everything to say who did what.
- Transaction signature may be the only trace a party leaves (they may have additional traces based on data included in a transaction).
 - To understand who's behind an account, we need to be sure whether only a single party controls the private key, e.g., the key could be compromised or shared (people still share passwords).
 - Therefore, good key management is critical to ensure authenticity.
- Most public blockchains try not to provide accountability by hiding the identity of transacting parties.
 - However, pseudonymous IDs in Bitcoin and Ethereum are too weak to prevent re-identification as they can be linked to IP addresses, withdrawals at exchanges, or even some social media discussions.
 - Cryptocurrencies like Zcash, Dash, and Monero try to provide anonymity like cash using techniques like transaction mixing services, zero-knowledge proofs, and ring signatures (a signature generated by multiple parties). Such coins are called "privacy coins" See <https://www.comparitech.com/crypto/anonymous-cryptocurrency-monero-zcash/> for details.
- Private blockchains are normally permissioned; hence, know who the users are. Typically use digital certificates issued by trusted certificate authorities.
- We need to consider KYC/AML-CTF regulations
 - KYC – Know Your Customer
 - AML – Anti-Money Laundering
 - CFT – Counter-Terrorism Financing
 - E.g., Australian AUSTRAC regulation requires KYC/AML by cryptocurrency exchanges. However, this can't be enforced at decentralised exchanges

- Authentication required by these regulations requires some off-chain mechanism(s) to establish an identity.
- Blockchain can be used to communicate or protect the integrity of KYC information, e.g. a trusted party may issue a certificate that is stored on a blockchain to confirm one's self-sovereign identity.

Authenticity

Many blockchain-based applications try to improve authenticity of a party or asset

- E.g., digital identity, NFTs, & goods on a supply chain

Digital assets

- Blockchains can ensure authenticity of entirely on-chain assets
- Hard to guarantee for other digital assets

Physical assets

- Hard to guarantee
- A unique physical “fingerprint”, e.g., DNA, diamonds, chemical composition?

Blockchain can track authoritative data signed by an authority confirming its authenticity

- E.g., Oracles

WK 09-01

11



- Authenticity is the degree to which the identity of a subject or resource can be proved to be the one claimed, i.e., it's the real thing.
- Many blockchain-based applications try to improve the authenticity of a party or asset, e.g., digital identity, non-fungible tokens, and goods on a supply chain.
- However, we need to be clear whether the authenticity is about the identity/asset or its container/reference.
- Digital assets
 - Blockchains can ensure the authenticity of assets entirely on-chain, e.g., Cryptokitties.
 - However, it is hard to guarantee other digital assets, e.g., NFT may include a URL of a digital asset. But it doesn't mean there's only one copy, and NFT represents only that asset. Digital watermarking help. But not straightforward to use.
- Physical assets are interesting
 - Typically it's hard to guarantee the authenticity of an asset purely on-chain.
 - However, some of the physical assets may contain unique physical fingerprints like DNA, unique patterns on a diamond/opal, and chemical composition. So the question is how representative are those data, whether can they be stored on-chain, and whether it's acceptable given an application's risk appetite.
- Blockchain can track authoritative data signed by an authority confirming its authenticity. Here blockchain proves the authenticity of the record signed by the authority and the actual authenticity of the asset is a claim of the authority.
 - Oracles are key components that connect the blockchain's virtual world with the real world in bringing such authoritative data into a blockchain. We trust the oracle or set of oracles.

Agenda

Security

Privacy

Data quality

Interoperability

- Layer 2 mechanisms

Privacy

Similar but different to confidentiality

- Simple distinction – confidentiality is about data, & privacy is about individual

Privacy is an individual's desire to control access of others to themselves & not just information

- Having control over extent, timing, & circumstances of sharing oneself
- e.g., physical privacy in your house, privacy on your crypto-asset ownership
- Individual can be a person, organisation, or an entity

Even for information, privacy has different regulations than confidentiality

- Privacy Act in Australia, General Data Protection Regulation (GDPR) in Europe
- Confidentiality comes from common law

Privacy is more than preventing unauthorised access to confidential, private, or other sensitive information

- Also, about what data are being collected, how & why data are shared or used ...

- Data breaches and misuse is a constant and common problems.
- Words “confidentiality” and “privacy” are often confused or perceived to be equivalent terms, but they represent related but different concepts.
- A simple way to think about these 2 terms is that confidentiality is about the data, and privacy is about the individual.
 - E.g., by protecting the confidentiality of your trading data, the privacy of your wealth can be protected.
- Privacy is an individual's desire to control access of others to themselves and not just information.
 - It is the ability of an individual or group to seclude themselves or information about themselves, and thereby express themselves selectively. It can be defined in terms of having control over the extent, timing, and circumstances of sharing oneself (physically, behaviourally, or intellectually) with others.
 - E.g., What you want to share, when you want to share, and how you want to share. Physical privacy in your home or privacy of on assets you own.
 - The individual doesn't have to be a person, it can be an organisation or any

distinct entity. But when it comes to most privacy legislation, it is about an individual's privacy. So, to distinguish individual's privacy from business privacy we sometimes use the term 'business confidentiality'.

- While privacy is governed by the Privacy Act, confidentiality isn't covered by a specific law. Instead, it comes from common law.
 - Key regulation that applies to data is General Data Protection Regulation (GDPR) in Europe.
- Guaranteeing privacy means guaranteeing that data can't uniquely identify any individual.
- However, privacy is more than preventing unauthorised access to confidential, private, or other sensitive information.
 - It also includes aspects like what data are being collected, how and why data are shared or used.

Requirements of Privacy Regulations

Privacy Requirements	Blockchain Support
Access (& timeliness of access) – right to access their personal data without undue delay	• Permissionless blockchains – Open to all • Permissioned blockchains – Possible to grant timely access
Rectification – right to correct inaccurate data concerning him/her	• Append only • Depends on ownership of ledger state
Restriction of usage – right to consent to use	• Smart contracts can make both consent & usage transparent & auditable • Permissioned blockchains – Possible to grant appropriate access • Permissionless blockchains – Open to all?

- Blockchain applications need to comply with regulations, but are there challenges or limitations?
- Typically privacy regulations specify a set of requirements. Here we compare key privacy requirements from GDPR and the level at that blockchains can support them.
- Access and timeliness of access is the right to access one's personal data without undue delay
 - Permissionless blockchains are open to all hence satisfy this requirement.
 - Whereas permissioned blockchains hide data from certain parties. However, if there's a need, it's possible to grant timely access.
- Rectification is the right to correct inaccurate data concerning him/her.
 - Blockchains are append-only. So what we can do is to send another transaction to update the data. However, this means both incorrect and correct data remain on the platform, with the information that incorrect data were superseded by correct data.
 - However, this depends on the ownership of the ledger state. If someone adds false data about you and if you don't have access to that smart contract you can't fix it.
- Restriction of usage is the right to consent to use.
 - Smart contracts can make both consent and usage transparent and auditable.
 - With permissioned blockchains it is possible to grant appropriate access.
 - However, with permissionless blockchains data are open to all, meaning we can't meet this requirement.

Requirements of Privacy Regulations – Cont.

Privacy Requirements	Blockchain Support
Portability of personal data – right to receive personal data in a machine-readable format for portability with other services	- Machine-readable, e.g., JSON - May not be portable
Right to be forgotten – right to remove personal data concerning him/her without undue delay	Append only

Request to Block Bing Search Results In Europe

In 2014, the Court of Justice of the European Union (CJEU) ruled that individuals have the right to request that Microsoft block search results on Bing in response to searches on your name if the results are inadequate, inaccurate, no longer relevant, or otherwise infringe on your privacy.

If you are requesting delisting of content you posted on a social media site, the tools available for you to remove this content from search results. You can find links to the help center for more information.

If you wish to report a concern to Bing that is not a "right to be forgotten" request, please visit the Bing Feedback page.

The screenshot shows the Facebook account deletion interface. It offers three main options: 'Permanently delete account', 'To keep messenger, deactivate instead', and 'Download your information'. The 'Permanently delete account' option is highlighted, showing a warning that once deleted, the account and its content will be removed and cannot be recovered. The 'To keep messenger, deactivate instead' option allows users to temporarily hide their profile while keeping their messages. The 'Download your information' option allows users to save a copy of their data before deletion.

WK 09-01

15



- Portability of personal data is the right to receive personal data in a machine-readable format for portability with other services.
 - The data format in blockchains is machine-readable, e.g., JSON. However, moving the data between blockchain platforms is not straightforward (e.g., moving all the history of a user account). Also, semantics may be different across blockchain platforms, e.g., UTXO vs account-balances. Lack of smart contract support or lack of representation like floating point numbers.
- The right to be forgotten is the right to remove personal data concerning him/her without undue delay. This is one of the hardest aspects of GDPR to comply with.
 - Blockchains are immutable by design; hence, removing data to comply with this requirement is not feasible
 - A possible approach be to store any sensitive data off-chain and maintain a "link" between a blockchain transaction record and the off-chain data.
- Here are 2 examples of Bing and Facebook support right to be forgotten. As a search engine, Bing will "try to" prevent access to some data.

Agenda

Security

Privacy

Data quality

Interoperability

- Layer 2 mechanisms

Data Quality

Strong data security guarantees may incentivise more data contributions

However, value of data depends on its quality

- Need to prevent garbage-in, garbage-out

More quality data could lead to better business outcomes for all stakeholders

Storing data on-chain doesn't automatically increase data quality

- Strong data security guarantees may incentivise more data contributions from users.
- However, the value of data depends on its quality not so much on the volume.
 - As discussed earlier, we need to prevent garbage-in, garbage-out scenarios.
- More quality data could lead to better business outcomes for all stakeholders.
- However, just because we store data on-chain doesn't automatically increase data quality.

Data Quality in Blockchains

Data Quality Attributes	Blockchain Support
Consistency – data are free from contradiction	Strong integrity properties
Traceability – audit trail of access/changes to data	- Immutable ledger - Accountability in private blockchains
Availability – data readily accessible	High read availability, low write availability
Compliance – data compliant with standards or regulations	- Protocol-level checks are quite limiting - Smart contracts are flexible, but have limitations
Confidentiality – data only accessible to authorised users	Private blockchains are better, but have limitations
Credibility – data regarded as true & believable by users	- Only for entirely on-chain assets - For others, we have to trust an oracle

WK 09-01

18



- Blockchains natively provide some quality guarantees regarding the data stored on them. Data quality can be assessed using a range of dimensions, some of which are detailed below:
 - strong integrity properties of blockchains provided through immutability.
 - Traceability means we need to have an audit trail of access/changes to data. Immutable ledger captures everything so we have an audit trail. In public blockchains, we also get accountability where we also know who changed the data.
 - Availability makes data readily accessible. As discussed many a time blockchains have high read availability, but low write availability.
 - Compliance ensures data are compliant with standards or regulations. Protocol-level checks are quite limiting as they don't focus on such aspects or even want to work against regulation. Smart contracts are flexible when it comes to embedding compliance rules, but have limitations on how expressive they can be or complex conditions to handle.
 - Confidentiality ensures data are only accessible to authorised users. Private blockchains are better as they can at least hide transaction details, but have limitations as they may still reveal secondary information like who is transacting with whom and how frequently.
 - Credibility is about authenticity where data can be regarded as true and believable by users. As discussed earlier, authenticity can be ensured only for entirely on-chain assets. For others, we have to trust an oracle.
 - Trustworthy data sources are integral parts of blockchain networks, but it is not subject to the underlying security mechanisms of blockchain technology.

How Architects Can Improve Data Quality in Blockchains?

Apply a hybrid on-chain & off-chain data architecture

Credibility

- Data sources aren't subject to underlying security mechanisms of blockchain
- Source data from multiple oracles
 - Use assurance certificates from auditors
- Record lineage of off-chain data on-chain
- Utilise a reputation management system or align incentives

Compliance

- Use smart contracts for simple quality/compliance assessments that are unlikely to change
- Perform complex or likely-to-change compliance assessments off-chain & record a proof on-chain

Managing data quality is an on-going issue and protocol and smart contracts are not flexible enough for compliance checking.

- Therefore we may need a hybrid of on-chain and off-chain data architecture.
- When it comes to data credibility data sources are not subject to the underlying security mechanisms of blockchain technology. Therefore, we don't have any control over them or independently validate their behaviour/data.
 - Possibly we can try to source data from multiple oracles so that we don't have to trust one party. This may happen through oracles we discussed so far it could be more qualitative like getting a certificate from a certified assurance body.
 - Blockchain is good to recording the lineage of off-chain data, i.e., storing everything about data like its generation, transformation, and storage.
 - Another option is to utilise some reputation management system to enhance trust in parties providing data. Alternatively, incentives can be set such that we penalise bad behaviour.
- To enhance data or business process compliance
 - We can use smart contracts to encode and enforce simple quality/compliance assessments that are unlikely to change in the near future. Rules that are likely to change are not good to be put on a smart contract as the contract need to be upgrades whenever compliance rules change.
 - Perform complex or likely-to-change compliance assessments off-chain. This can be supplemented with on on-chain proof general by specialised hardware like Intel SGX.

Question

Which of the following statement(s) are True?

	True	False
The trust in a blockchain-based application solely relies on the trust in the blockchain platform		✓
A blockchain can ensure the authenticity of a digital asset stored off-chain		✓
Encrypt on-chain data pattern can't provide privacy forever	✓	
Blockchain anomaly is an example of loss of integrity on a blockchain platform	✓	
Blockchains can't generally support the "right to be forgotten" privacy requirement	✓	

- False – A blockchain cannot always ensure the authenticity of a digital asset stored off-chain, e.g., think about an NFT for digital art stored off-chain.
- True – Encrypt on-chain data patterns can't provide privacy forever as keys can be compromised and technology enhancements may render current encryption algorithms useless, e.g., quantum computing.
- True – Blockchain anomaly is an example of loss of integrity on a blockchain platform as order of transaction recording on-chain and off-chain can be different.
- True – Blockchains can't generally support the right to be forgotten privacy requirement as it is immutable. There's some effort to develop redactable blockchains where you can remove selected data without breaking consensus process.

Agenda

Security

Privacy

Data quality

Interoperability

- Layer 2 mechanisms

Interoperability

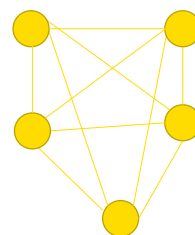
Ability of 2 systems to work together

- Lack of it leads to fragmentation, vendor lock-in, risk of obsolescence, ...

Degree to which 2 or more systems, products, or components can **exchange information** & **use information** that has been exchanged – *ISO/IEC 25010:2011*

Challenging due to

- Semantic differences
- Diversity of data representations, software, systems, & networks
- Too many integration points
 - At most $n(n-1)/2$ connections for n nodes



- Interoperability is the ability of 2 software or systems to work together.
- Lack of interoperability leads to fragmentation, vendor lock-in, risk of obsolescence, and lack of standards.
- More formally, ISO/IEC 25010:2011 standard defines it as the degree to which 2 or more systems, products, or components can exchange information & use the information that has been exchanged. This focuses on 2 aspects:
 - Ability exchange data
 - Ability to use that data
- Interoperability in information systems is quite challenging due to several factors.
 - 2 systems to integrate may be conceptually different. E.g., one system may represent users using their user name and another may assign a unique number.
 - Data representations – 2 systems may store the same data in different formats both at the software and hardware level, e.g., representation of dates and floating point numbers.
 - Software – 2 software trying to talk to each other may be developed in different programming languages, representation of strings and arrays are usually different.
 - Systems – One system may run Windows while the other runs Linux
 - Networks – One would use a wired network while the other may use wireless or use different network protocol versions, e.g., one use TLS version 1.0 and the other 1.2
 - No of the integration points has a quadratic growth (i.e., n^2) compared to the number of systems/services to integrate. See animation. With 10 blockchains, we need 45 integrations.

Interoperability – Cont.

Needs to happen at different levels

1. Inter-organisation coordination, i.e., consensus to work together
2. Business process integration, i.e., unified business process
3. Semantic application integration, i.e., means the same thing
4. Syntactic application integration, i.e., ability to map from one to another
5. Physical integration, i.e., actual connectivity

Interoperability is domain specific

- Level 1 to 3 tend to be application & domain specific

Standardisation is key for widespread interoperability

- Mostly technical & cover level 4 & 5

- Interoperability needs to happen at different levels, e.g.,
 - Inter-organisation coordination is essential to interoperate, where consensus needs to be reached on how to work together. Also, issues need to be resolved as they arise.
 - Business process integration is required to asynchronies and has a unified business process across all involved parties. However, this does not mean the same process needs to run everywhere, and different fragments can run in different places.
 - Semantic application integration is required to ensure all systems mean the same thing, e.g., a customer or an asset is uniquely identified.
 - Syntactic application integration does not require everyone to represent the data in the same way. Rather we need the ability to map from one data representation to another. E.g., conversion of units.
 - Physical integration is where the actual connectivity happens. This is also at different levels from software, and hardware to networks.
- Interoperability is domain-specific. E.g., how interoperability is handled in supply chains will be different from financial markets or healthcare.
 - Level 1 to 3 above tends to be application specific. However, several aspects of integration can be discussed at the domain level.
- Standardisation is key for widespread interoperability.
 - Most of the standards exist for levels 4 and 5 which include more technical aspects of integration.

Interoperability Standards

Many standards

- ISO/IEC 10021-6:2003 Information technology – Message Handling Systems (MHS)
- ISO/IEC 19941:2017 Information technology – Cloud computing — Interoperability and portability
- ISO/IEC 40210:2011 Information technology – W3C SOAP Version 1.2 Part 1: Messaging Framework (2nd Edition)
- ISO 20022-8:2013 Financial services – Universal financial industry message scheme
- IEEE 2418.2-2020 – IEEE Standard for Data Format for Blockchain Systems

In development

- ISO/TC 184/SC 5 – Interoperability, integration, and architectures for enterprise systems and automation applications
- ISO/TC 307 – Blockchain and distributed ledger technologies technical committee
- IEEE Computer Society Blockchain and Distributed Ledger Standards Committee

- There are many interoperability standards, and some of them covering different aspects are listed here.
 - The first one is generic, while the 2nd one is specific to cloud computing. 3rd one is very technical and focuses on a SOAP (Simple Object Access Protocol), a standard for web-based services
 - 4th one is on messaging related to financial services. ASX CHESS+ will use this messaging standard
 - The last one is specifically on blockchain data formats
 - ISO/IEC 10021, Information Technology – Message Handling Systems (MHS) standard defines the overall system and service of an MHS and serves.
 - ISO/IEC 19941:2017 specifies cloud computing interoperability and portability types, the relationship, and interactions between these two cross-cutting aspects of cloud computing and common terminology and concepts used to discuss interoperability and portability, particularly relating to cloud services.
 - ISO 20022 is a standard for electronic data interchange between financial institutions. It describes a metadata repository containing descriptions of messages and business processes and a maintenance process for the repository content. It covers financial information transferred between financial institutions that includes payment transactions, securities trading, and settlement information, credit and debit card transactions and other financial information.
- Several interoperability standards are in development, some of them specifically on blockchains.
 - ISO/TC 307 <https://www.iso.org/committee/6266604/x/catalogue/p/0/u/1/w/0/d/0>
 - ISO/WD TR 6277 - Blockchain and distributed ledger technologies – Data flow model for blockchain and DLT use cases
 - ISO/AWI TS 23516 - Blockchain and Distributed Ledger Technology — Interoperability Framework
 - IEEE CS TS <https://sagroups.ieee.org/bdlsc/#1616054054487-9cb13c78-4c4a>
 - P3204 - Standard for Blockchain Interoperability - Cross Chain Transaction Consistency Protocol
 - P3205 - IEEE Draft Standard for Blockchain Interoperability - Data Authentication and Communication Protocol

Blockchain Interoperability

Ability of different blockchains to **exchange data & move digital assets** while **maintaining state & uniqueness**

- Public-public, public-private, private-private; on-chain & off-chain
- Single & multi-token TXs

Without interoperability

- Blockchains are data/asset silos that fragment a market
- Restricts composability limiting use cases & innovation

Challenging due to

- Single source of truth
- Differences in finality
- Data embedded in smart contracts
- Immutability vs rollbacks
- TX, data, & account representations

WK 09-01

25



- Blockchain interoperability refers to the ability of different blockchain networks to exchange and leverage data between one another, as well as to move digital assets between respective blockchains. In doing so we want to maintain the state and uniqueness of those data/assets.
 - Depending on the use cases, Interoperability could be between 2 public blockchains, a public and a private one, or 2 private ones.
 - It could involve a single token (e.g., an asset moving from one chain to another) or multiple tokens (e.g., swapping assets on 2 chains).
 - Interoperability between a BC and entities outside the BC is also sometimes considered under interoperability.
- Without interoperability, blockchains are data/asset silos that fragment a market. It could also hinder users from benefiting from features offered by other platforms to compose applications with much greater benefits.
- Achieving interoperability in blockchains is nontrivial and complicated by several factors, such as:
 - Blockchains are supposed to maintain a single source of truth. Hence, we can allow the same data/asset to be active on multiple blockchains. Hence, interoperability is more than copying data. Instead, when minting an asset on the target blockchain, it must be burned on the source blockchain.
 - Different consensus protocols lead to different forms of finality. Dealing with probabilistic finality is challenging as a transaction could be cancelled in the future.
 - Data embedded in smart contracts make it difficult to move data without explicit support from smart contracts.
 - Immutability and rollbacks don't go together. Hence, the only option is to use a cancelling transaction. But for certain applications, it may be too late as the new asset owner may have already transferred it out.
 - Data and account representations make it difficult to map from one form to data to another or from one use to another. Also, the same transaction may not be able to include different forms of data, such as different signatures or address formats.

Cross-Chain Technology

Notary schemes

Oracles

- Similar to notary schemes with source/target being off-chain

Sidechains & relays

Hash-Time Lock Contract (HTLC)

Blockchain of blockchains

- Blockchain interoperability solutions are known as cross-chain technologies. Here we list several major categories.
- Notary schemes use a trusted notary to convey data between 2 blockchains to enable data/asset transfer.
- Oracles are similar to notary schemes where data or assets transfer is between blockchain and off-chain components.
- Sidechains are secondary blockchains that have a peg to the main chain. Relays are a special form of sidechain implementation where the relay is another blockchain that is used to record transactions/events from one blockchain and make it available to one or more other blockchains.
- A Hash Time Lock Contract (HTLC) is an atomic transaction mechanism to swap assets across 2 or more blockchains.
- Blockchain of blockchains is a hierarchical design where a high-level parent links all child chains, which act like shards.
- There is also middleware, such as Hyperledger Cactus, that presents a unified interface/API for DApps to operate across multiple blockchains. Similar to database TX managers, these handle atomic swaps and rollbacks. We will not discuss these in class.

Notary Schemes

A trusted notary monitors multiple chains

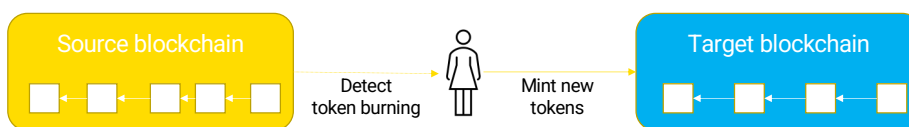
- May stake crypto to gain trust

Triggers TXs in a chain upon an event taking place in another chain

- Typically, provided by centralised & decentralised exchanges

Use multiple notaries to prevent centralisation & single point of failure

- E.g., Ripple Interledger project



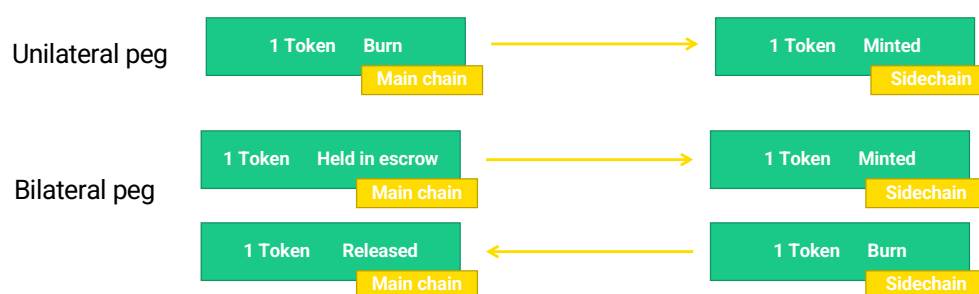
- This scheme uses a trusted notary to monitor and link multiple chains.
 - The notary may stake cryptocurrency as a way of gaining trust. In case of misbehaviour by the notary, the stake could be removed.
- The notary monitors designated transactions or events on one chain and then triggered transactions in another chain.
 - E.g., as seen in the figure, it can monitor token-burning transactions or events on a given contract on the source blockchain. It then mints new tokens on the target blockchain. Instead of minting, it may act as an oracle confirming the occurrence of transaction/event to the target blockchain's token contract.
 - Newly minted tokens could be on a 1:1 rate or any other rate.
 - The data/asset flow may happen in either direction.
- Notary services are typically provided by centralised & decentralised exchanges.
- A notary centralises control, is a single point of failure, and a weak link in blockchain trustless assumption. These issues could be reduced by having multiple notaries that prevent centralisation and a single point of failure.
 - E.g., Ripple Interledger uses a Byzantine-fault-tolerant consensus algorithm to achieve consensus among a set of notaries on whether a given event took place, and then issues a signature that can be used to finalise payments conditional on this consensus.

Sidechains (Secondary Chains)

Sidechain is another blockchain that is connected to a main chain

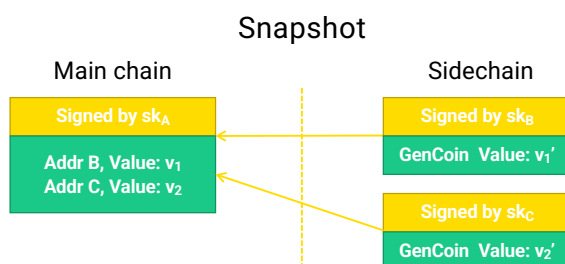
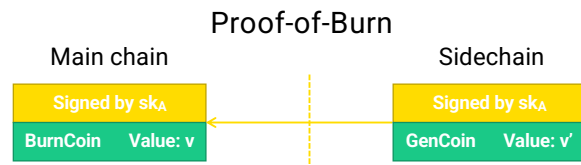
- Used to create an “extension” of main chain with lower TX fees, higher throughput, etc., but benefit from integrity of main chain

Assets can be transferred from one chain to another using a peg



- A sidechain (aka secondary chain) is a mechanism for 2 existing blockchains to interoperate, scale, and be upgraded in which one blockchain (main chain) considers another blockchain as an extension of itself (the sidechain).
- Sidechains are semantically like parent chains but may have differences like lower PoW difficulty or PoS or PoA, while parent chain uses PoW.
- They are used to create a “smaller” chain (or extension of the main chain) with lower transaction fees, higher throughput, etc., but benefit from the integrity of the main chain.
- An example is a 2-way peg, a mechanism for transferring assets between the main and side chains. A 2-way peg works in the following manner:
 - A user, operating on the main chain sends X tokens to a custom address that locks assets.
 - Those funds are locked on the main chain using an escrow contract, and a corresponding number of tokens are created on the sidechain (usually 1:1, but other ratios are possible). You will need some mechanism to convey this information from the main chain to the side chain, e.g., a notary.
 - The user can now use the tokens on the sidechain.
 - Eventually, the user can transfer back the tokens to the main chain, which causes assets on the sidechain to be locked or destroyed.

2-Way Peg



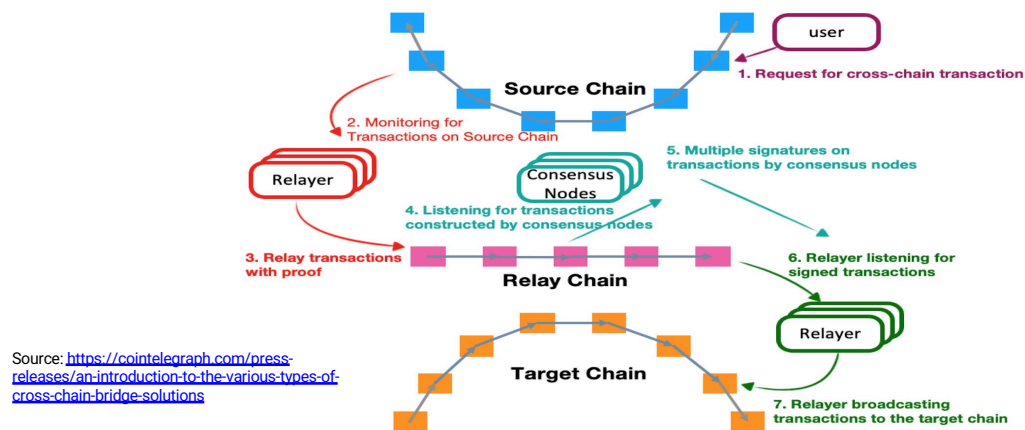
Types of 2-way pegs

- Simplified payment verification
- Centralised 2-way peg
- Federated 2-way peg

- The main chain can have multiple side chains.
- Some use cases require assets to be locked or burned on the main chain before creating them on the sidechain.
- Others may allow an asset to remain on both chains. E.g., in the snapshot example, a snapshot of asset values is taken from the main chain, and new assets are issued on 2 different sidechains.
- There are 3 major types of two-way pegs:
 - Simplified payment verification (SPV)
 - Centralised 2-way peg
 - Federated 2-way peg

Simplified Payment Verification (SPV)

Relay chain is a sidechain common to multiple blockchains



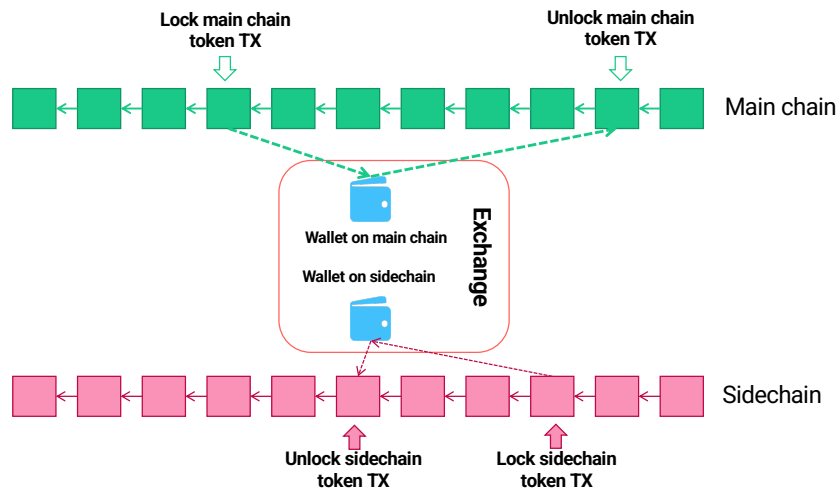
WK 09-01

30



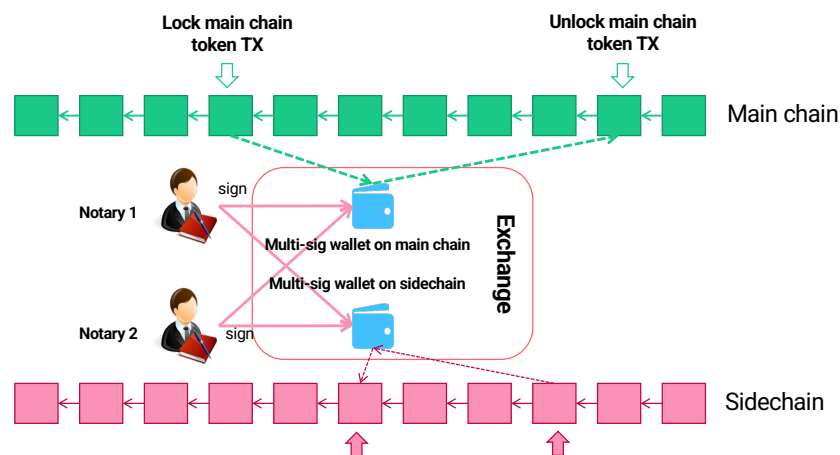
- Here we consider simplified payment verification with a relay blockchain.
- A relay chain is a sidechain common to multiple blockchains.
- In the relay model, a set of relay nodes are deployed in each blockchain network (these nodes can also be part of the relay network), which is responsible for monitoring and synchronising the transaction data of that blockchain to the relay chain.
- The consensus nodes of the relay chain verify the validity of cross-chain transactions and may trigger the execution of the corresponding transaction on the target chain.
- The following steps are illustrated in the diagram:
 1. A user initiates a cross-chain transaction request in the source chain (could be main chain or sidechain)
 2. Relay nodes monitor the source chain and synchronise the transaction data to the relay chain.
 3. The relay chain consensus node verifies the validity of the transaction, e.g., validates the block header and presence of the transaction in the Merkle tree.
 4. The consensus node constructs the corresponding transaction.
 5. A supermajority of consensus nodes signs the transaction, forming a signature set.
 6. The relay nodes for the target chain monitor the transaction and signatures.
 7. The relay node carries the transaction to the target chain and initiates relevant action(s).
- Rather than establishing a relay chain, light clients in the parent chain can act as relays to the sidechain. Therefore, relays are considered a specific implementation of sidechains.
- This approach is used in BTC-relay and Ethereum contract for Bitcoin SPV.
- The public sidechain might not have settlement finality. Hence, finality is a problem for such blockchains.

Centralised 2-Way Peg



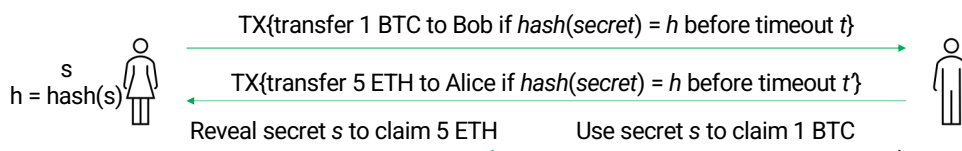
- This is essentially a notary scheme where a centralised or decentralised exchange holds assets for either the main or sidechain.
- Exchange enforces the promise of locking tokens on the source chain before unlocking tokens on the target chain. This is like depositing funds at Bitcoin banks such as Coinbase or Xapo. View these Bitcoin banks' internal ledgers as sidechains to Bitcoin.

Federated 2-Way Peg



- This approach tries to minimise centralisation through the exchange.
- It uses a group of notaries to control the locked assets, where most have to approve to unlock the funds using a multi-signature scheme.
- This setup is better than having a single controller of the funds but may still centralise control.
- To achieve true decentralisation, the notaries should be carefully selected so they are located in different jurisdictions and different geographies, as well as each should have a higher reputation and better security.

Hash-Time Lock Contract (HTLC)

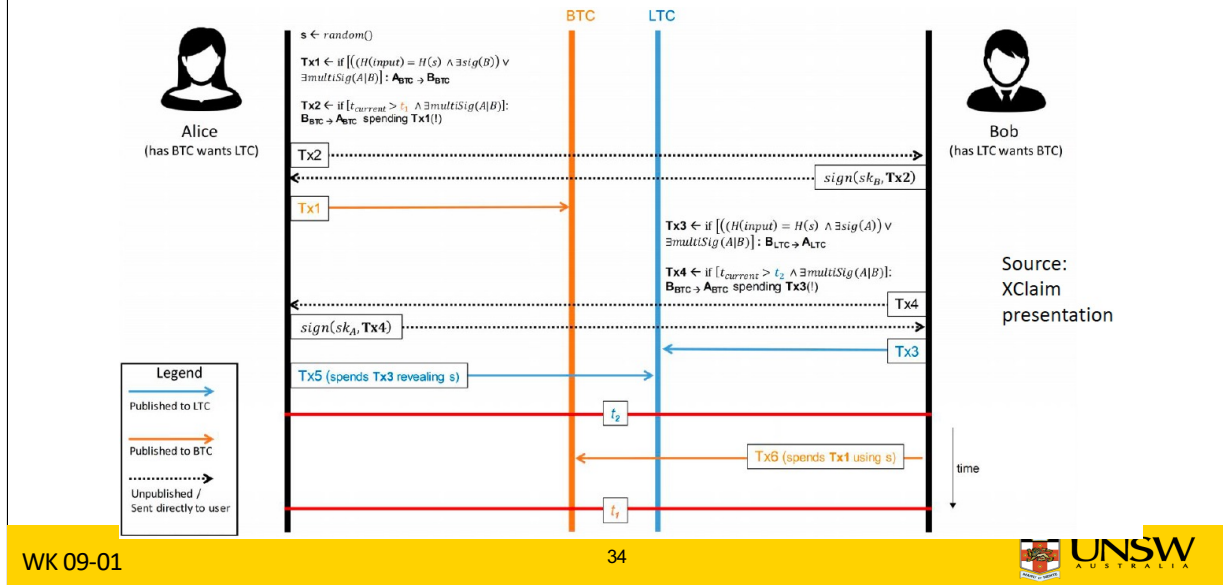


Achieves TX atomicity through a hash-time lock

1. Alice generates a random number s , & calculates its hash $h = \text{hash}(s)$
2. Alice sends a TX to Bob, allowing him to claim BTC if he knows s
3. Bob sends a TX to Alice, allowing her to claim ETH if she knows s
4. Alice claims ETH by submitting secret s
5. Bob can claim BTC as s is now revealed on ledger
6. If Alice doesn't present s before timeout, each party's locked assets can be claimed

- Hash Time Lock Contract (HTLC) (aka hash lock time lock or hashed time-lock contracts) is an atomic transaction mechanism to swap assets across 2 or more blockchains.
- The figures give an overview of HTLC though it can be implemented in several ways and can be extended to operate across 2+ actors.
- Suppose Alice and Bob want to swap BTC and ETH at a 1:5 rate. The following steps are involved:
 1. First, Alice generates a random number, s , and calculates its hash $h = \text{hash}(s)$.
 2. Alice sends a TX to Bob (how this can be done is discussed in the next set of slides), allowing him to claim Alice's BTC if he knows s .
 3. Bob sends a TX to Alice, allowing her to claim ETH if she knows s .
 4. Alice claims ETH by submitting the secret to the blockchain.
 5. Bob can claim BTC as s is now revealed on the ledger. Alternatively, Alice may send s to Bob after she gets ETH.
 6. If Alice doesn't present s before the timeout, each party's locked assets can be claimed by submitting the TX.
- Known examples:
 - Kaileido offers a simple process to swap tokens using HTLCs securely.
 - The Bitcoin Lightning Network supports multi-hop payment channels by linking existing payments through a chain of HTLCs. This enables parties to transact beyond their payment channel.
 - AirSwap supports atomic token swaps with a guaranteed price. It also supports swaps via Metamask wallet and custom swaps with parties trading tokens.

HTLC Using TXs



- Here's an HTLC implementation using only transactions. It swaps BTC with LTC (Litecoin).
- For this to work, transactions should have scripting functionality or simple logic checks like in Bitcoin.
 - First, Alice generates a random number s , and calculates its hash $h = \text{hash}(s)$.
 - Alice generates and sends TX1 to the Bitcoin blockchain, allowing Bob to claim Alice's BTC if he knows s .
 - Alice also generates TX2, which checks for the timeout. If timeout, it returns Alice's BTC to her, consuming TX1.
 - Bob confirms TX2 by signing it as TX2 require signatures from both parties in case the secret is not revealed.
 - Then Bob sends TX3 to the Litecoin network, allowing Alice to claim LTC if she knows s .
 - Bob also generates TX4, which checks for the timeout. If timeout, it returns Bob's LTC to him, consuming TX3.
 - Alice confirms TX4 by signing it.
 - Alice claims LTC by submitting secrets to the blockchain via TX5.
 - Bob can claim BTC as s is now revealed on the ledger.
 - If Alice doesn't present s before timeout, each party's locked assets can be claimed by submitting TX2 and TX4, respectively.
- Bob risks not submitting the secret before timeout if Alice submits the secret only last minute.

Blockchains of Blockchains

Blockchain interconnecting other blockchains

- Consensus protocol organises blocks containing a set of cross-chain TXs
- Provides accountability for parties issuing TXs on different blockchains
- Provides a holistic view of each underlying blockchain

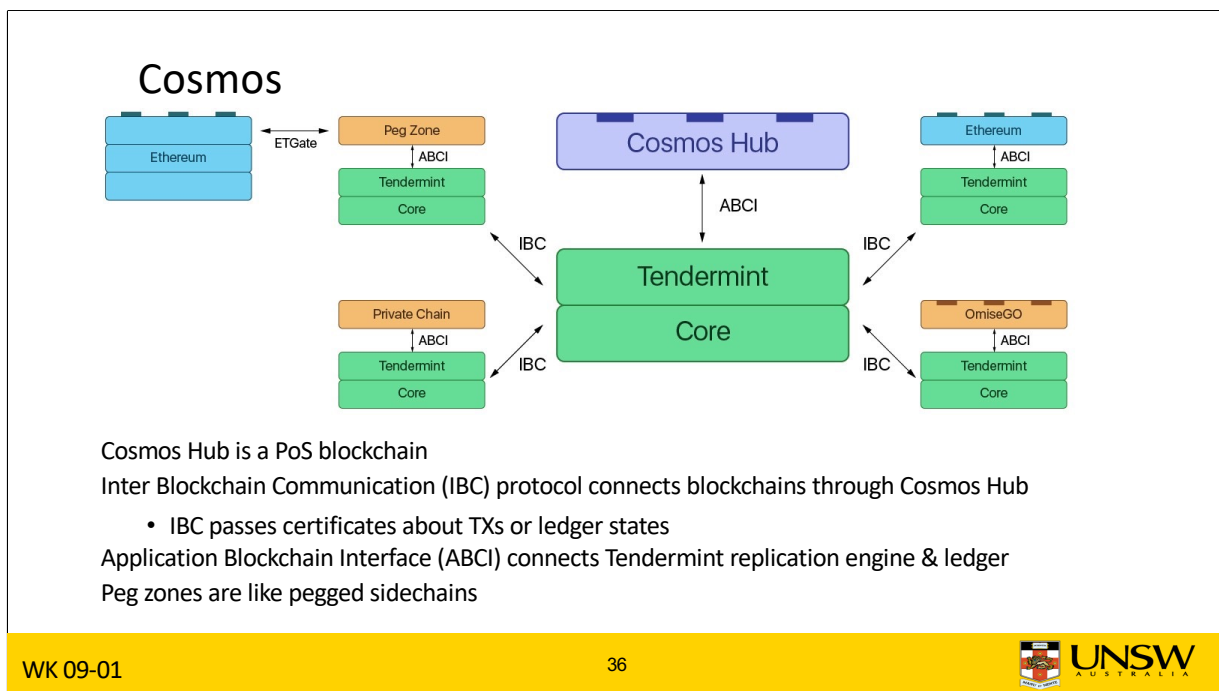
Focus on data & digital assets

Mostly based on hub & spoke model

Examples

- Cosmos
- Polkadot
- Cardano

- Blockchain of blockchains (aka internet of blockchains) is an interoperability approach where a blockchain interconnects with other blockchains.
 - Consensus protocol in the interconnecting blockchain organises blocks containing a set of cross-chain TXs.
 - It provides accountability for parties issuing transactions on different blockchains.
 - Provides a holistic view of each underlying blockchain.
- Most of the interoperability solutions discussed so far had a digital asset focus (mainly crypto). Whereas these solutions are more general but extremely complex to build.
- Most implementations are based on some form of hub and spoke model, where the hub interconnects other blockchains rather than establishing many connection pairs between blockchains.
- Some of the popular examples include Cosmos, Polkadot, and Cardano.

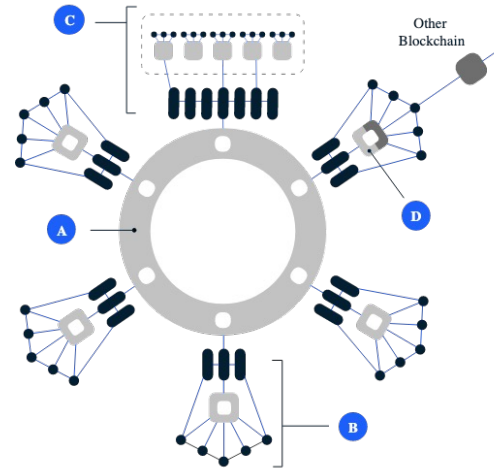


- Cosmos Hub is the main blockchain that acts as a central connector for all of the blockchains in the Cosmos Network. It is a multi-asset, proof-of-stake blockchain powered by Tendermint.
 - Tendermint is a Practical Byzantine-Fault Tolerant (PBFT) state machine, along with a peer-to-peer network gossiping protocol.
- Inter Blockchain Communication (IBC) protocol allows blockchains to interact with others through Cosmos Hub by creating certificates about transactions or ledger states.
 - Blockchains are connected in a hub and spoke model to the Cosmos Hub. The spokes of the network are called zones.
- Application Blockchain Interface (ABCI) defines the boundary between the Tendermint replication engine and the ledger. The ABCI is the only way for the blockchains state to be updated, and only Tendermint has access to state-changing functions for the blockchain.
- Peg zones resemble the pegged sidechain mechanism.
 - To do this we need to have a shared security model where the Cosmos Peg Zone Validator is also running an Ethereum node. The special Validator approves the interactions between the 2 chains. This is a complicated infrastructure to set up, and you must trust the team running the Peg Zone.
 - The actual exchange of assets would require an Ethereum smart contract to lock in Ether, which would create new tokens in the Peg Zone that represent “Cosmos-Ether” that can be sent around the Cosmos Network through IBC. On the Cosmos side, the Validator would lock up Atoms (native cryptocurrency in Cosmos), which would, in turn, create an ERC-20 Atom token that can be sent around Ethereum.

Polkadot

PoS blockchain

- A. Relay chain – core that manages cross-chain interoperability & consensus
- B. Parachains – heterogeneous blockchains connected to Polkadot
- C. Parathreads – similar to parachains but based on pay-as-you-go model
- D. Bridges – allow connection with external networks
- E. Collators – produce valid parachain blocks
- F. Validators – responsible for proposing a parachain block to relay chain



- Polkadot is a PoS blockchain that runs a set of shards and can connect to other blockchains. It supports cross-chain computation and cross-chain registries.
- It has a large set of roles/nodes, and key ones are illustrated in the figure.
- The relay chain is the core of the Polkadot network. It manages shard security, cross-chain interoperability, and consensus.
- Parachains refer to all the heterogeneous blockchains that are connected to Polkadot. Parachains can have their tokens, specific functionalities, use cases, and governance.
- Parathreads are also similar to Parachains but abide by the pay-as-you-go model (i.e., they connect when they want). These are the chains that don't require continuous connectivity to the network.
- Bridges allow Parathreads and Parachains to connect and interact with external networks like Bitcoin and Ethereum.
- Collators produce blocks within a Parachain.
- Validators are responsible for proposing a Parachain block to relay chain.
- Each Parachain relies on a central shard within the ecosystem for cross-chain communication and security.

Agenda

Security

Privacy

Data quality

Interoperability

- Layer 2 mechanisms

Layer 2

Layer 0 – Main/base blockchain

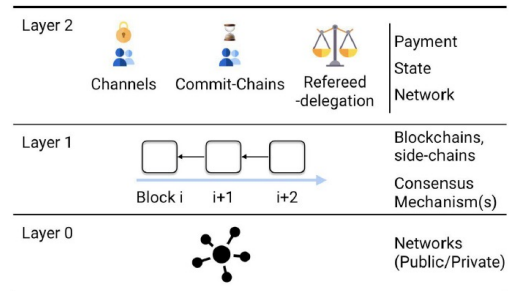
Layer 1 – Sidechains

- Change in base protocol, e.g., low difficulty, PoW to PoS/PoA, large block size, & sharding

Layer 2 – Services built on Layer 1

- Process & record TXs off-chain
- Tethered/pegged to a sidechain
- E.g., payment channels, rollups, plasma

Enhanced scalability, performance, & lower cost



Source: L. Gudgeon et al., "Sok: Layer-two blockchain protocols", Int. Conf. on Financial Cryptography and Data Security, Feb. 2020.

- Sidechains are considered layer 1 solutions (built on top of layer-0 solutions which is the main blockchain) to implement layer-2 solutions, such as payment channels.
 - Sidechains typically run the same blockchain with a few changes to the base protocol like low difficulty, PoW to PoS/PoA, large block size, and sharding.
 - There's no clear agreement on Layer 0 and 1, note that the figure and bullet points are a bit different. But there seems to be agreement on Layer 2.
- The second layer allows off-chain transactions between users through exchanging messages tethered/pegged to a sidechain.
- Sometimes, Layer 0 is also called Layer 1, and sidechains are considered as Layer 2.
- Key benefits of Layer 2 solutions include enhanced scalability (i.e., handling more transactions), performance (i.e., low latency), and lower cost
- Next, we discuss a couple of Layer 2 solutions.

State Channels (Payment Channels)

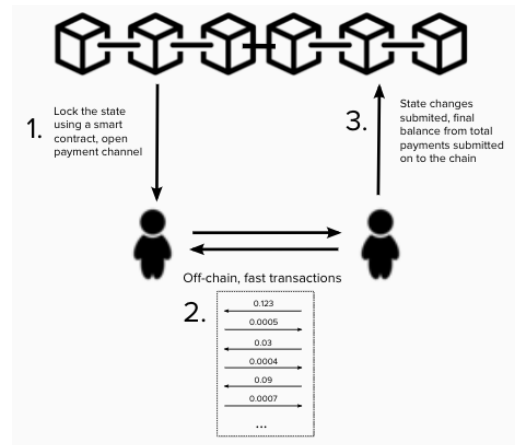
Public blockchains aren't attractive for micropayments

- TX fee $\gg$ monetary value of micropayment TX

- Long TX commit time

State channels process & record TXs off-chain & eventually settle on-chain

- Lock away assets on-chain (1 or both sides)
- Transact off-chain while maintaining intermediate states on payment channel
- Update/settle on-chain
 - Frequency of settlement depends on use cases

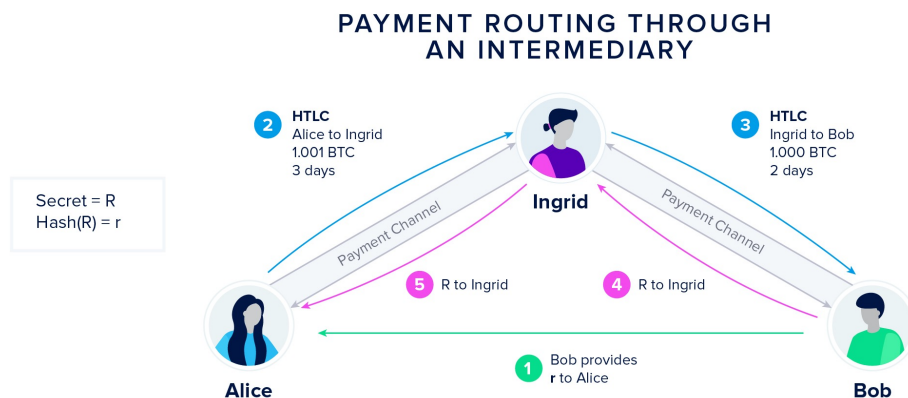


- Micro-payments TXs are too expensive to be performed on-chain because the TX fee might be higher than the monetary value associated with the TX (assuming a public blockchain is used). Also, the main chain's TX commit time (including finality) could be too high.
 - Therefore, it makes sense to perform micropayments off-chain, given their relatively low risk.
- As seen in the figure, payment channels process and record TXs off-chain and eventually settle on-chain.
 - First, one or both parties lock assets (e.g., ETH) on the main chain's smart contract. Typically, this contract uses multi-signature.
 - Then they establish a channel for payment between the 2 parties.
 - Then based on the locked asset value, 2 parties transact off-chain while maintaining intermediate states on the payment channel, i.e., keep a record of TXs and balances. Ideally, each TX is signed by all parties involved in the channel.
 - On-chain balance could be updated periodically or when closing the payment channel to settle the balance. The frequency of settlement depends on the use case.
- When closing a channel, if both parties unanimously approve the last state, the channel is settled immediately. Even a single party can request to close a channel (the other party is no longer contactable). However, in such cases, there's a time

window that allows a missing party to prove a more recent state (each TX has a nonce or a sequence no) if he/she doesn't agree with the currently submitted final state.

- Such a payment channel can be generalised for arbitrary state updates for more general purposes than monetary values. Such channels are known as “state channels”
- See [State Channels | ethereum.org](https://ethereum.org/en/developers/docs/state-channels/)

Payment Routing via State Channels



Source: <https://www.horizen.io/blockchain-academy/technology/expert/state-and-payment-channels/>

WK 09-01

41

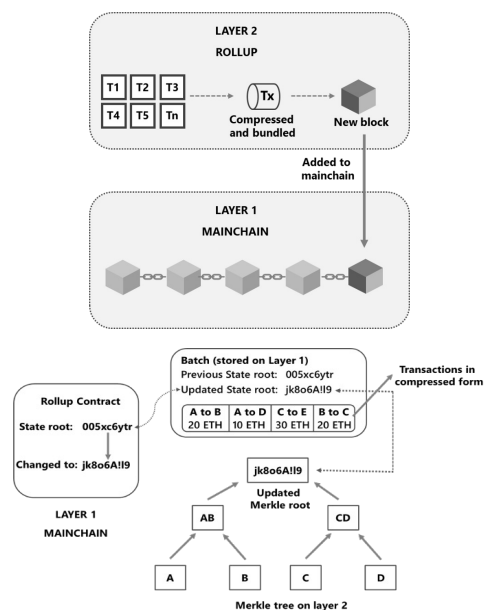


- A set of payment channels between 2 parties can be used to route payments between parties that don't have a payment channel.
- In the figure, Alice and Bob don't have a payment channel. However, Alice and Bob have a payment channel with Ingrid.
- Here we illustrate how 2 HTLCs (Hash-Time Lock Contracts) can be used to transfer payment from Alice to Bob.
 1. Bob creates the secret R and shares its hash r with Alice.
 2. Subject to this hash, Alice creates an HTLC indicating the amount to transfer to Ingrid if she knows the secret. It also indicates a timeout of 3 days.
 3. Subsequently, Ingrid establishes an HTLC indicating the amount to transfer to Bob if he knows the secret. It also indicates a timeout of 2 days.
 - The difference in value between 2 HTLCs will be given as payment for Ingrid's service to route the payment (i.e., Ingrid will receive $1.001 - 1 = 0.001$ BTC).
 - Timing is also important, as once Bob gets BTC from Ingrid, she needs to have sufficient time to claim payment from Alice.
 4. Finally, Bob reveals the secret R to the 2nd HTLC to receive the payment.
 5. As the secret is revealed, Ingrid can submit R to 1st HTLC to get BTC from Alice.
- This idea can be extended beyond parties that are 2-hops away from each other into multiple hops. Routing algorithms can be used to find a path between 2 parties that wish to transact and then a chain of HTLC contracts can be established with appropriate payment values and timeouts

Rollups

Layer 2 runs an EVM, but no block building
 Deploy “rollup contract” on main chain that stores state root of rollup layer
 Lock main chain assets in a smart contract
 TXs at rollup layer use locked in asset value
 Record Merkle tree root of state & compressed TX data on rollup contract
 Use “fraud proofs” to challenge state root
 If state update is proven to be invalid, roll back batch of TXs

Source: <https://medium.com/techskill-brew/layer-2-blockchain-scaling-solutions-channels-sidechains-rollups-and-plasma-part-16-79819e058ef6>



- Rollups usually involve only 2 layers. Hence, sometimes the main chain is considered Layer 1.
- Layer 2 runs a smart contract execution engine like EVM. However, Layer 2 does not build blocks.
 - Multiple validators may run this EVM and double-check each other's work. If only a single validator is used (i.e., centralised) it's called a sequencer.
- First, a party providing rollup service deploys the “rollup contract” onto the main chain that stores the state root of the rollup layer.
- Any party that wishes to use the rollup service locks main chain assets in a smart contract, e.g., ETH, ERC-20 tokens, or any other accepted asset.
- Transactions at the rollup layer can use the locked-in asset value, i.e., the asset is minted on the rollup layer.
- The rollup layer executes transactions and keeps track of the state changes. Transaction fees need to be paid, but much lower than a typical transaction in Ethereum.
- The rollup layer then calculates the Merkle tree root of all states.
- The Merkle tree root of state and compressed transaction data is recorded on the rollup contract on the main chain. This is called a batch update.
- Use “fraud proofs” to challenge state root within a given time limit from the time

batch gets included in the rollup contract.

- Fraud proof tries to prove an asset was double spent or sent beyond its value.
- If the state update is proven to be invalid, roll back the batch of transactions by essentially replacing the current state root in the rollup contract with the previous state root.
- There are 2 rollup techniques:
 - Optimistic rollups – See [Optimistic Rollups | ethereum.org](https://ethereum.org/en/rollups/optimistic/)
 - Assume transactions are valid by default and rely on fraud proof to challenge within a specified time window. The sequencer/validator responsible for including the incorrectly executed transaction in a block receives a penalty (the validator keeps a bond like in PoS). Party of the penalty is provided to the challenger and the rest is burned.
 - There are several ways to check a fraud-proof on-chain. See [Optimistic Rollups | ethereum.org](https://ethereum.org/en/rollups/optimistic/) for 2 such mechanisms
 - Can offer up to 10-100x improvements in scalability
 - Write TXs to Ethereum as *call data*, reducing gas costs for users. This includes the Merkel root of the ledger state (state root) and a batch of transactions (transaction root)
 - Zero-knowledge rollups – See [Zero-Knowledge rollups | ethereum.org](https://ethereum.org/en/rollups/zero-knowledge/)
 - Perform computation off-chain and submit only a validity proof – a validity proof demonstrates with cryptographic certainty that the proposed changes to the ledger state are truly the result of executing all the transactions in the batch. Validity proof is shorter than compressed transactions stored in optimistic rollups.
 - SNARKs or STARKs algorithms are typically used to generate validity proof. These require specialised hardware and more on-chain computation; hence, increasing transaction fees.
 - A major limitation of optimistic rollups is the longer withdrawal time. If anyone suspects a transaction to be fraudulent, they can challenge it and submit fraud proof within the time duration of 7 days. Thus, users have to wait around one week to withdraw their assets from layer 2 rollups.
- These techniques drastically improve throughput, but not latency and finality

Plasma

A hierarchy of blockchains

- Child chains use simplified consensus process & has high performance

Lock root chain assets in a smart contract

Issue assets on a child chain

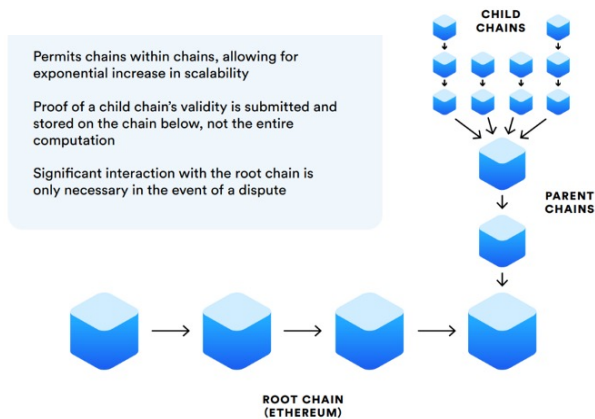
TXs at child chain use those assets

Store Merkle tree proof of a child chain's

validity on chain below

Root chain is involved only in resolving disputes

- Use "fraud proofs" to challenge Merkle tree proofs
- If TX is proven to be invalid, unlock assets on root chain



Source: <https://medium.com/@marcocavicchioli/plasma-cash-new-scalability-solution-for-the-ethereum-network-f7c0b889db7d>

- Plasma is a high-level specification with several proposal implantations, e.g., Plasma Cash.
- As seen in the figure, plasma establishes a hierarchy of blockchains where child chains anchor on to parent chain, and parent chain anchor onto the root chain (aka the main chain).
 - Child chains typically use simplified consensus processes (e.g., lower difficulty, PoS, or PoA) and have high performance.
- To use a child chain uses lock root chain assets in a smart contract at the root chain.
- Based on the locked, Issue assets on the chosen child chain.
- Then the user can transact at the child chain using those assets.
- Store Merkle tree proof of a child chain transactions to prove the validity of the chain below. The parent chain then stores its Merkle tree proof on the chain below.
- The root chain is involved only in resolving disputes.
 - Similar to rollups, users can use "fraud proofs" to challenge Merkle tree proofs of child chains or any chain above.
 - If a transaction is proven to be invalid, assets locked on the root chain can be released.